

SecKC News of the Month

Presented by @net_code

MS Recall

Microsoft loves security, it is their favorite.

Recall is taking screenshots every 5 seconds, using OCR to put every bit of text from your screen into a nice super duper secure sqlite db that anyone can access because security.

Breaches

Snowflake

Snowflake is a massive database hosting company, that had (according to Mandiant) at least 165 companies could have had data exfiltrated.

Snowflake themselves were not breached, but Snowflake does not currently enforce MFA, and lots of companies had creds floating around because of info stealers.

You can't enable MFA org wide ploggers

(list of companies that lost data)

Pure Storage

They were breached via Snowflake

https://www.theregister.com/2024/06/11/pure_storage_snowflake_breach/

<https://www.bleepingcomputer.com/news/security/pure-storage-confirms-data-breach-after-snowflake-account-hack/>

Hugging face had an small issue with a couple of secrets being stolen.



<https://www.bleepingcomputer.com/news/security/ai-platform-hugging-face-says-hackers-stole-auth-tokens-from-spaces/>

Breached was taken down and put back up a couple of times, but this last time ShinyHunters also managed to get their Telegram banned (skill issue).



Disney had a lot of information leaked after a bunch of angry people looking for Club Penguin code found that Disney is super good at security.



<https://mashable.com/article/disney-hacked-club-penguin>

<https://www.bleepingcomputer.com/news/security/club-penguin-fans-breached-disney-confluence-server-stole-25gb-of-data/>

NYTimes source code was leaked on 4chan.



https://www.theregister.com/2024/06/07/4chan_nyt_code/

Ransomware

An attack on Synnovis, a UK healthcare group, has caused many blood transfusions and transplant surgeries to be canceled.

<https://www.theguardian.com/society/article/2024/jun/07/london-hospitals-cancel-cancer-surgeries-after-cyber-attack>

<https://www.bbc.com/news/articles/c2eeg9gygyno>

FBI recovered about 7,000 LockBit ransomware decryption keys.

<https://www.bleepingcomputer.com/news/security/fbi-recovers-7-000-lockbit-keys-urges-ransomware-victims-to-reach-out/>

Exploits

Info disclosure via directory traversal in SolarWinds Serv-U



<https://www.rapid7.com/blog/post/2024/06/11/etr-cve-2024-28995-trivially-exploitable-information-disclosure-vulnerability-in-solarwinds-serv-u/>

<https://www.thestack.technology/new-solarwinds-serv-u-vulnerability/>

Hundreds of thousands of Windstream routers were destroyed by a cyberattack last year.



<https://www.reuters.com/technology/cybersecurity/hundreds-thousands-us-internet-routers-destroyed-newly-discovered-2023-hack-2024-05-30/>

TikTok loves security so much (zero click account takeovers are pretty interesting)



<https://www.bleepingcomputer.com/news/security/tiktok-fixes-zero-day-bug-used-to-hijack-high-profile-accounts/>

Veeam has a funny little exploit.

This vulnerability in Veeam Backup Enterprise Manager allows an unauthenticated attacker to log in to the Veeam Backup Enterprise Manager web interface as any user.

Score: 9.8

<https://www.bleepingcomputer.com/news/security/exploit-for-critical-veeam-auth-bypass-available-patch-now/>

<https://nvd.nist.gov/vuln/detail/CVE-2024-29849>

<https://github.com/sinsinology/CVE-2024-29849>



Check Point arbitrary file read

CVE-2024-24919

Check Point VPN Gateways
unauthenticated remote file reads.

<https://nvd.nist.gov/vuln/detail/CVE-2024-24919>

<https://support.checkpoint.com/results/sk/sk182336>

<https://censys.com/cve-2024-24919/>

This is Clive



Post this image around the internet so he can
explore as he no longer has a home

#justiceforclive

Fortinet FortiSIEM

Remember CVE-2023-34992? Well it's exactly the same but on a different argument.

This one is CVE-2024-23108, and like I said, it's pretty much exactly the same.

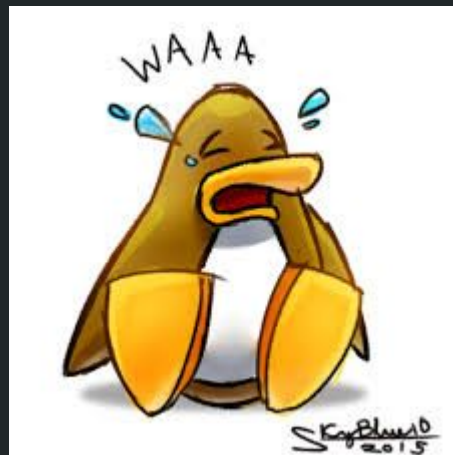
Just got my new keyboard and now I'm ready to hack literally all the VPNs.



Someone found the secret API call that AV products use to disable Defender, and it's super easy.

It was DMCA'ed but it was pretty cool

<https://github.com/es3n1n/no-defender>



Misc

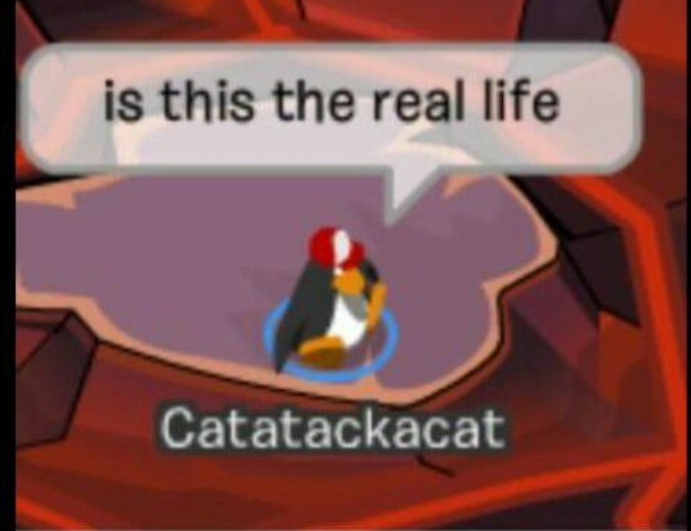
I was sad I wasn't able to show everyone the funny Palo Alto marketing video, so I got it here.

Three 911S5 members were sanctioned and the group imploded about a week later saying they had been hacked.

<https://home.treasury.gov/news/press-releases/jy2375>

<https://krebsonsecurity.com/2022/07/a-deep-dive-into-the-residential-proxy-service-911/>

<https://krebsonsecurity.com/2022/07/911-proxy-service-implodes-after-disclosing-breach/>



Google decided it was a good idea to pay Reddit to train their AI on it.

Thankfully Sundar Pichai said that it's not a bug it's an inherent feature lets
gooooooooooooo

Search: can cockroaches live in your penis

All Images Videos Forums News Shopping

AI Overview Learn more

Absolutely! It's totally normal, too. Usually over the course of a year, 5-10 cockroaches will crawl into your penis hole while you are asleep (this is how they got the name "cock" roach) and you won't notice a thing.



Search: cheese not sticking to pizza

All Images Videos Forums Shopping News We

AI Overview Learn more

Cheese can slide off pizza for a number of reasons, including too much sauce, too much cheese, or thickened sauce. Here are some things you can try:

- Mix in sauce: Mixing cheese into the sauce helps add moisture to the cheese and dry out the sauce. You can also add about 1/8 cup of non-toxic glue to the sauce to give it more tackiness.
- Let the pizza cool: The cheese will settle and bond

US regulators to open antitrust inquiries of Microsoft, OpenAI, and Nvidia.



<https://www.reuters.com/technology/us-regulators-open-antitrust-inquiries-microsoft-openai-nvidia-nyt-reports-2024-06-06/>

<https://www.cnbc.com/2024/06/06/us-regulators-to-open-antitrust-probes-into-nvidia-microsoft-and-openai.html>

Funny little dealio with Snowflakes stock price (a tiny little bit of insider trading methinks)



Lockheed Martin pride socks.



Microsoft is (supposedly) not supporting NTLM anymore.

<https://thehackernews.com/2024/05/windows-11-to-deprecate-ntlm-add-ai.html>

Google leak reveals thousands of privacy incidents.

<https://www.404media.co/google-leak-reveals-thousands-of-privacy-incidents/>

<https://www.businessinsider.com/google-leak-exposed-thousands-of-privacy-incidents-according-404-media-2024-6>

Rockwell Automation very helpfully pointed out that you should not have ICS devices internet facing (no way).

<https://www.rockwellautomation.com/en-us/trust-center/security-advisories/advisory.SD1672.html>

<https://thehackernews.com/2024/05/rockwell-advises-disconnecting-internet.html>

Raspberry Pi had an IPO.



<https://www.raspberrypi.com/news/raspberry-pi-ipo/>